

Threat Containment Procedures for OAuth and API Rate Limiting

Category: Procedures

Model: CONT-API-005

Description: This document outlines step-by-step containment procedures involving OAuth token revocation, tightening conditional access policies, and applying API rate limits to specific subnets. It includes specific detection signatures, incident artifacts, IAM audit notes, network block lists, and checkout failure codes identified during recent threat-hunting activities. Additionally, it provides a comprehensive playbook for partner OAuth review.

Table of Contents

- [1. Introduction](#)
- [2. Detection Signatures and Indicators](#)
- [3. Analysis of Artifacts and Audit Data](#)
- [4. Threat Identification and Context](#)
- [5. Containment Procedures](#)
 - [5.1 OAuth Token Revocation Playbook](#)
 - [5.2 IAM Audit and Endpoint Analysis](#)
 - [5.3 Network Blocking Strategies](#)
 - [5.4 API Rate Limiting Playbook](#)
- [6. Partner OAuth Review Playbook](#)
- [7. Appendices](#)

1. Introduction

This document serves as a comprehensive procedural guide for containment and mitigation of OAuth and API abuse incidents identified within our network infrastructure. Using real-world detection signatures, suspicious artifacts, and network indicators collected over the past six months, it provides detailed, step-by-step instructions to security responders for swift containment of threats, including OAuth token revocation, tightening access policies, network blocklisting, and API throttling.

2. Detection Signatures and Indicators

Effective threat containment hinges on accurate detection of malicious activity. The following signatures were used to identify recent compromise indicators:

- **BEACON-12xx:** Custom beacon signatures associated with data exfiltration scripts communicating over non-standard ports.
- **C2-DNS-30xx:** Domain generation algorithms (DGA) used for command-and-control server communication, e.g., `c2-host-01.example`.

Additional detection artifacts include:

- EDR alerts indicating presence of `mshta.exe` spawning PowerShell processes with encoded commands (base64 encoded payloads).
- SHA256 hashes representing known malicious payloads, for example:

```
abc123def456ghi789jkl012mno345pqrs678tuv901wxyz234abc56
```

- Suspicious IAM audit notes including:
 - Unusual service account auto-creation events
 - Scope IDs such as `SCOPE-PROD-API-ADMIN` with

3. Analysis of Artifacts and Audit Data

Understanding the artifacts associated with threat activity is crucial for effective detection and subsequent containment. Key findings include:

3.1 Network Indicators

Description	Value	Notes
Malicious Domain	c2-host-01.example	Associated with C2 communications identified through DNS logs
ASN	ASN-64512	Associated with suspicious IP ranges used in attacker infrastructure

3.2 Checkout Failure Codes

Observed failure codes during incident include:

- PAY-408: Payment gateway timeout errors, indicating possible API abuse
- GATEWAY-52: Gateway connection resets attributed to rate limiting or network filtering
- CART-ERR-1203: Cart submission errors linked to abnormal traffic patterns

4. Threat Identification and Context

Recent threat-hunting efforts have uncovered signs of compromise indicating

abuse of OAuth tokens and API endpoints:

- High frequency of token refresh attempts from compromised service accounts
- Presence of unusual scope IDs such as `SCOPE-PROD-API-ADMIN` associated with unauthorized API access
- Detection signatures (**BEACON-12xx**, **C2-DNS-30xx**) consistent with command and control activity

The aggregation of these signals highlights the need for immediate containment and remediation actions.

5. Containment Procedures

This section provides detailed, procedural steps to contain the threat, including OAuth token revocation, access policy restrictions, network filtering, and API throttling.

5.1 OAuth Token Revocation Playbook

Objective: Immediately invalidate all compromised OAuth tokens to prevent further unauthorized access.

Prerequisites

- Access to OAuth authorization server admin console
- List of compromised token identifiers and associated client IDs

Procedure

1. Identify active tokens linked to suspicious activity, e.g., using audit logs or token introspection endpoints.
2. Access the OAuth server's management console or API interface.
3. Use the token revocation endpoint, e.g., `POST /oauth/revoke`, providing token identifiers:

```
{
```

```
"token": "ACCESS_TOKEN_HERE"
}
```

4. Verify revocation status via token introspection or by attempting API calls with revoked tokens.
5. Log all revocation actions for audit compliance.

Verification and Follow-up

- Ensure that all tokens flagged during detection are revoked.
- Monitor activity logs for attempts to reuse revoked tokens.

Prevention Tips

- Implement short-lived tokens with automatic expiration.
- Employ continuous monitoring for unusual token activity.

5.2 IAM Audit and Endpoint Analysis

Key findings from IAM audit logs include:

- Unusual service account auto-creation events (e.g., user-initiated or bot-driven)
- Scope IDs such as `SCOPE-PROD-API-ADMIN` being accessed outside normal operational hours or from suspicious IP ranges

Action Steps

1. Review recent IAM audit logs focusing on service account activity related to `SCOPE-PROD-API-ADMIN`.
2. Identify any unauthorized scope escalations or unexpected auto-creation of service accounts.
3. Disable or rotate compromised service accounts.
4. Apply conditional access policies restricting scope access based on trusted device and IP parameters.

5.3 Network Blocking Strategies

Network layer containment involves blocking malicious domains and IP ranges identified during threat analysis:

Domain / IP Range	Description	Status
c2-host-01.example	Malicious command-and-control server domain	Blocked
ASN-64512	Suspicious ASN associated with attacker infrastructure	Blocked via ASN filtering

Implement blocks via firewall rules, DNS filtering, and IP reputation services to prevent further malicious communication.

5.4 API Rate Limiting Playbook

To prevent abuse of API endpoints, apply rate limits to suspicious subnet ranges or client IDs:

Procedure

1. Identify high-volume API consumers with suspicious patterns (e.g., exceeding 1000 requests/min).
2. Configure rate limiting rules in API Gateway or proxy layers:

```
Rate limit: 100 requests per minute per subnet/IP
Target: Subnets associated with suspicious activity
Response: 429 Too Many Requests with retry-after header
```

3. Implement custom alerting for rate limit breaches.
4. Gradually tighten limits if suspicious activity persists or escalates.

Monitoring & Verification

- Monitor logs for 429 responses and adjust thresholds accordingly.

- Review attack vectors to update rate-limiting policies proactively.

6. Partner OAuth Review Playbook

In response to detected suspicious activity involving partner integrations, the following procedures should be followed to review and re-approve OAuth trust relationships:

6.1 Review Checklist

- Verify all active OAuth client credentials associated with partner domains.
- Confirm scope assignments align with established principles; particularly review scopes like `SCOPE-PROD-API-ADMIN`.
- Check OAuth token activity logs for anomalies such as request spikes or unusual IP locations.
- Revoke any tokens linked to suspicious or compromised clients.
- Require re-authentication and approval for partner OAuth clients post-review.

6.2 Review Process

1. Notify all engaged partners about the review and potential token revocations.
2. Conduct a joint audit of OAuth client configurations and activity logs.
3. Implement additional security measures such as IP whitelisting or device fingerprinting for ongoing access.
4. Issue renewed OAuth credentials after successful review.
5. Update partner access policies accordingly and document all actions for compliance.

7. Appendices

7.1 Glossary of Terms

OAuth

An open standard for access delegation commonly used as a way to grant websites or applications limited access to user accounts on other services.

API Throttling

The process of limiting the number of API requests a client can make within a specified period.

C2-DNS

Command-and-Control Domain Name Signatures used in threat detection.

SCOPE

The set of permissions associated with an OAuth token.

7.2 References

- OAuth 2.0 Framework Documentation — <https://oauth.net/2/>
- API Gateway Rate Limiting Guidelines — [Internal Documentation]
- Threat Detection Signatures — Security Team Reports (March 2024)